Báo cáo triển khai và quản trị hệ thống

Đề 29 Website Công thức Nấu ăn Recipe

Báo cáo trình bày hệ thống chia sẻ công thức nấu ăn triển khai trên Ubuntu bằng Docker Compose. Phần mềm sử dụng PHP và MySQL, có phpMyAdmin, Nginx reverse proxy, Prometheus, Grafana, Loki và Promtail. Mã nguồn và cấu hình được quản lý trên GitHub theo mã sinh viên DTC245220017.

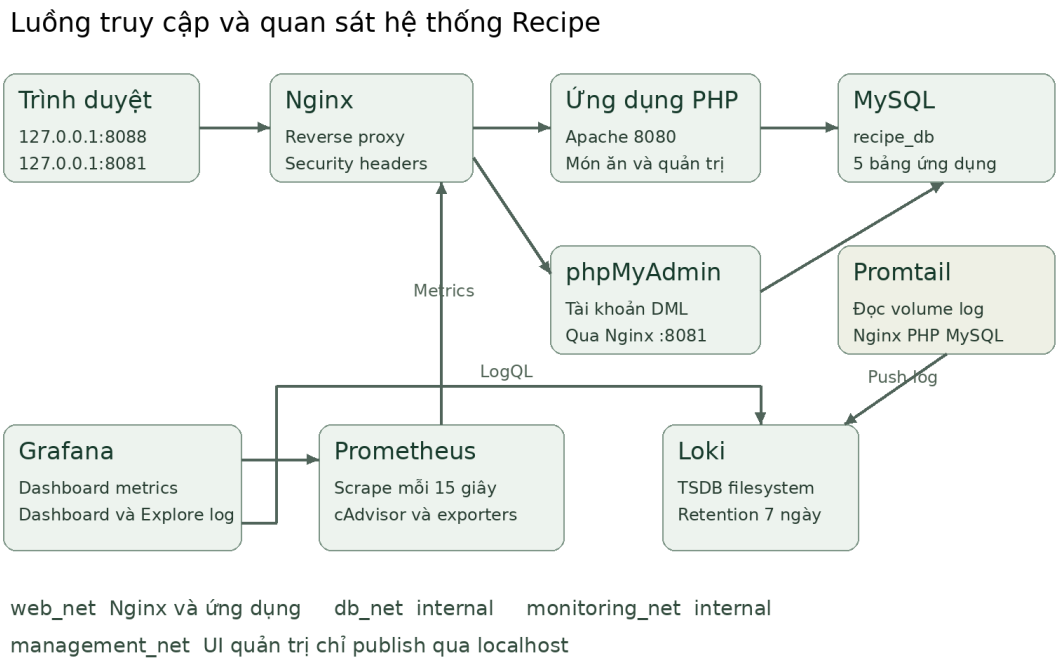
Tại thời điểm kiểm tra 23/10/2026, hệ thống đã vượt qua 51/51 kiểm tra tích hợp. Kết quả được thu trực tiếp từ HTTP, API giám sát, truy vấn log và cấu hình runtime Docker.

Phạm vi và tiêu chí nghiệm thu

Tiêu chí	Sản phẩm và minh chứng
GitHub	Mã nguồn, README, cấu hình và ba commit theo các giai đoạn kỹ thuật
Ứng dụng và database	Danh mục, món ăn, nguyên liệu, cách nấu, quản trị và phpMyAdmin
Reverse proxy	Truy cập qua Nginx với security headers cơ bản
Giám sát	Metrics container, Nginx và MySQL; dashboard Grafana
Log tập trung	Log ba nguồn, Loki và ít nhất ba truy vấn LogQL
Hardening	Non-root, mạng nội bộ, giảm quyền, bảo vệ bí mật và ứng dụng
Báo cáo và demo	Ảnh giao diện, kết quả kiểm thử và hướng dẫn vận hành

Các phần tiếp theo lần lượt mô tả kiến trúc, mã nguồn, dữ liệu, chức năng ứng dụng, reverse proxy, giám sát, log, hardening và quy trình vận hành. Báo cáo phân biệt kết quả đã kiểm tra với giới hạn của môi trường lab; không xem việc container khởi động là bằng chứng duy nhất của chức năng.

1 Kiến trúc và luồng hoạt động



Hình 1 Kiến trúc ứng dụng và các lớp quan sát

Người dùng truy cập Nginx tại cổng 8088. Nginx chuyển yêu cầu tới Apache của ứng dụng PHP trên cổng nội bộ 8080. Ứng dụng đọc và ghi MySQL qua PDO. Cổng 8081 của Nginx chuyển tới phpMyAdmin để xem dữ liệu bằng tài khoản ứng dụng; không công bố cổng MySQL ra host.

Mạng	Thành phần và mục đích
web_net	Nginx, ứng dụng và phpMyAdmin
db_net internal	MySQL, ứng dụng, phpMyAdmin và MySQL Exporter
monitoring_net internal	Prometheus, Grafana, exporters, Loki và Promtail
management_net	Kết nối các UI giám sát với cổng loopback trên host

Prometheus chủ động scrape metrics từ các exporter; Grafana truy vấn Prometheus để vẽ biểu đồ. Với log, Promtail đọc các volume chỉ đọc của Nginx, PHP và MySQL rồi gửi dữ liệu tới Loki. Grafana sử dụng datasource Loki để truy vấn LogQL. Các luồng dữ liệu này được tách khỏi luồng người dùng truy cập website.

2 Quản lý mã nguồn và khởi tạo

Repository công khai của bài làm: https://github.com/longphan632000/DTC245220017_De29-Recipe. Khung thư mục tham khảo dự án Blog CMS, gồm app/src, mysql, nginx, prometheus, loki và promtail. Dự án bổ sung provisioning Grafana, script khởi tạo và bộ kiểm thử để tái lập cấu hình. Mật khẩu, khóa bí mật và bản dump database không nằm trong lịch sử Git.

Commit	Nội dung kỹ thuật
e7a4049	feat: deploy Recipe PHP app with MySQL phpMyAdmin and hardened Nginx proxy
7662cc7	feat: add Prometheus exporters and provision Grafana monitoring dashboard
9393eaa	feat: centralize logs with Loki Promtail and verify security end to end

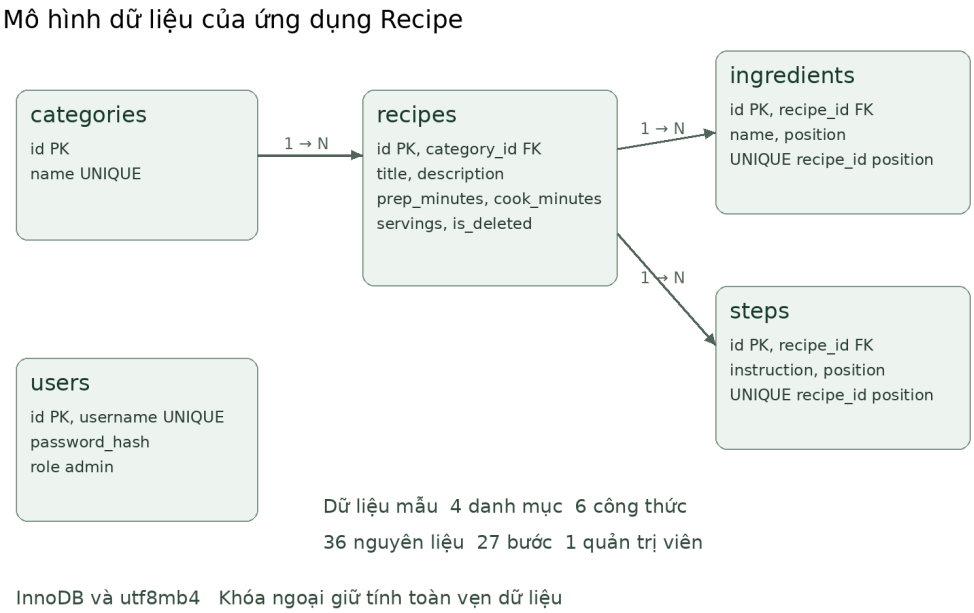
Cài đặt từ repository

```
git clone https://github.com/longphan632000/DTC245220017_De29-Recipe.git
cd DTC245220017_De29-Recipe
python3 scripts/setup.py
docker compose ps -a
python3 scripts/verify.py
```

Script setup tạo các mật khẩu ngẫu nhiên trong .env, chuẩn bị secret cho phpMyAdmin, build image và khởi động MySQL. Sau khi database healthy, script nạp schema và dữ liệu mẫu, giới hạn quyền DB, tạo tài khoản quản trị ứng dụng rồi chạy các thành phần còn lại. Chạy lại script giữ tài khoản đã có và không xóa volume.

Thành phần	Phiên bản hoặc cơ chế cố định
Ứng dụng	PHP 8.3 và Apache từ image ghim digest
Database	MySQL 8.0.46; phpMyAdmin 5.2.3
Grafana	13.2.2; tắt tự cập nhật plugin khi chạy
Log	Loki 3.7.8; Promtail 3.6.8
Image khác	Ghim SHA256 digest trong Compose hoặc Dockerfile

3 Thiết kế cơ sở dữ liệu



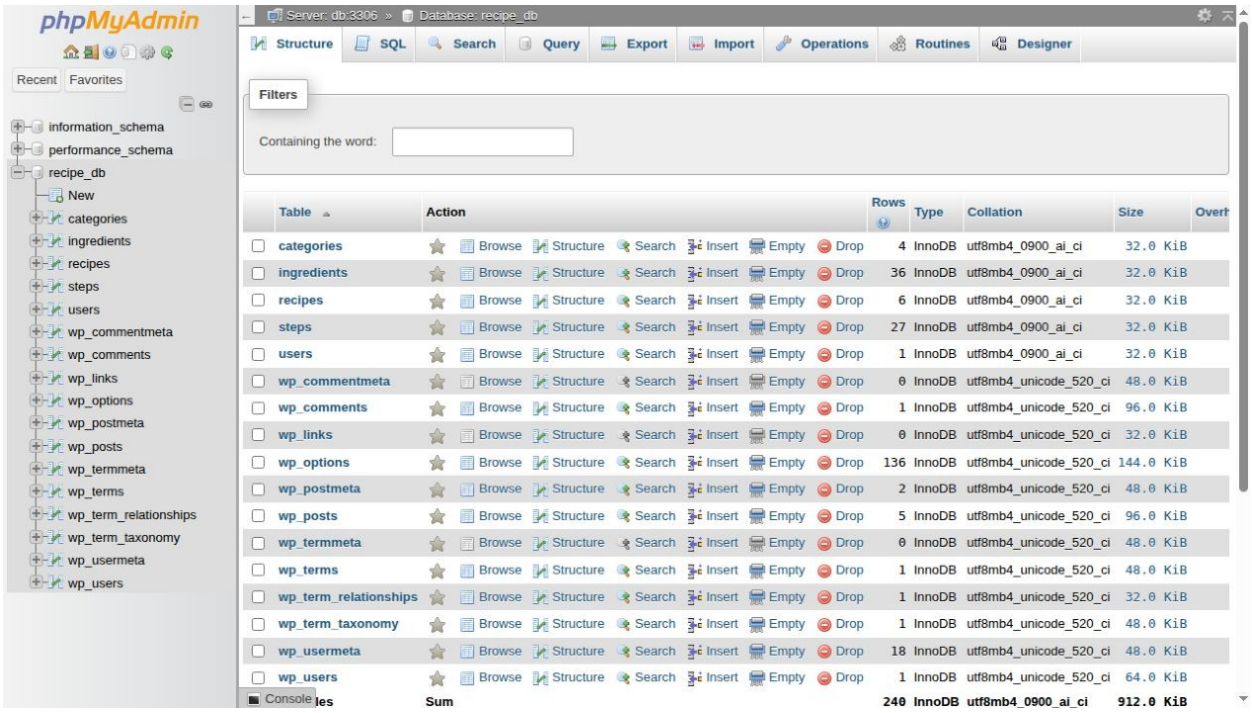
Hình 2 Quan hệ giữa năm bảng của ứng dụng Recipe

Bảng	Nội dung	Số dòng mẫu
categories	Tên danh mục món ăn	4
recipes	Món ăn, mô tả, thời gian, khẩu phần, trạng thái	6
ingredients	Nguyên liệu và thứ tự trong công thức	36
steps	Hướng dẫn chế biến theo thứ tự	27
users	Tên đăng nhập, password hash và vai trò	1

Schema dùng InnoDB, utf8mb4 và khóa ngoại. recipes liên kết categories; ingredients và steps liên kết recipes, có ràng buộc thứ tự trong từng món. Mật khẩu không lưu ở dạng rõ trong users. Lưu trữ công thức chỉ đổi is_deleted; khôi phục đưa công thức trở lại danh sách công khai.

Trên máy Ubuntu hiện tại, các bảng wp_ từ lần cài WordPress ban đầu được giữ để bảo toàn dữ liệu. Ứng dụng PHP không sử dụng chúng. Cài mới từ repo chỉ tạo năm bảng nêu trên; dữ liệu cũ đã có bản sao lưu cục bộ trước khi triển khai theo khung PHP.

Kiểm tra cơ sở dữ liệu bằng phpMyAdmin



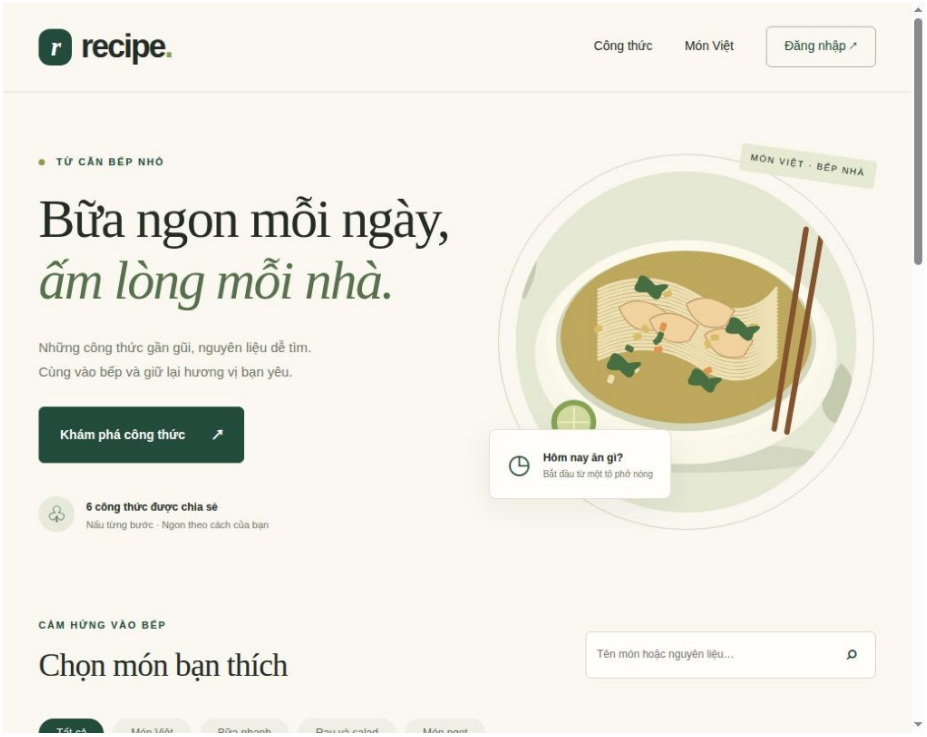
Hình 3 Database Recipe được truy cập thành công bằng phpMyAdmin

Giao diện phpMyAdmin truy cập qua Nginx tại http://127.0.0.1:8081. Sau khi đăng nhập bằng recipe_user, cột bên trái hiển thị recipe_db và các bảng dữ liệu. Năm bảng đầu gồm categories, ingredients, recipes, steps và users là các bảng mà ứng dụng PHP sử dụng.

Ảnh chụp xác nhận bốn danh mục, sáu công thức, 36 dòng nguyên liệu, 27 bước chế biến và một quản trị viên. Các bảng có tiền tố wp_ phía dưới là dữ liệu WordPress cũ được giữ trên máy hiện tại. Kết quả cài mới độc lập từ repo chỉ có đúng năm bảng ứng dụng, đã được kiểm chứng bằng truy vấn information_schema.

Tài khoản này chỉ có quyền DML, đủ để xem và sửa bản ghi trong database được cấp. phpMyAdmin không cho phép đăng nhập bằng root. Bộ kiểm thử xác minh đăng nhập thành công và đọc được cấu trúc các bảng; đồng thời lệnh thử CREATE TABLE bằng tài khoản ứng dụng bị MySQL từ chối, chứng minh việc giới hạn quyền đã có hiệu lực.

4 Giao diện và tìm kiếm công thức



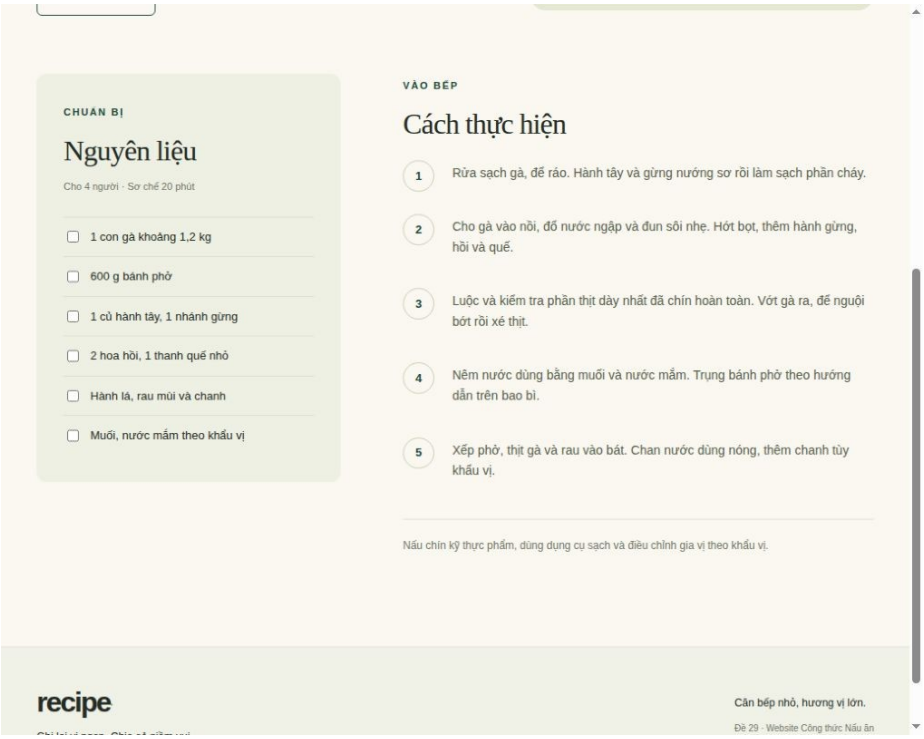
Hình 4 Trang chủ Recipe được phục vụ qua Nginx

Trang chủ hiển thị các công thức công khai, thời gian nấu, khẩu phần, độ khó và danh mục. Dữ liệu lấy từ MySQL, không phải nội dung chỉ hiển thị cố định trong HTML. Sáu món mẫu gồm phở gà, bánh mì gà xé, cơm rang rau củ, canh chua cá, salad và chè đậu xanh.

Ô tìm kiếm hỗ trợ tên món, mô tả và nguyên liệu. Kiểm thử từ khóa “me chín” trả đúng món canh chua. Bộ lọc “Rau và salad” trả một công thức salad. Người dùng có thể kết hợp từ khóa và danh mục; khi không có kết quả, giao diện hiển thị hướng dẫn thử lại.

CSS có bố cục thích ứng với màn hình nhỏ. Các hình minh họa SVG đi kèm source giúp website chạy độc lập với dịch vụ ảnh bên ngoài. Nội dung nhập từ người dùng được escape trước khi hiển thị; câu lệnh tìm kiếm dùng tham số PDO.

5 Chi tiết món ăn và nguyên liệu



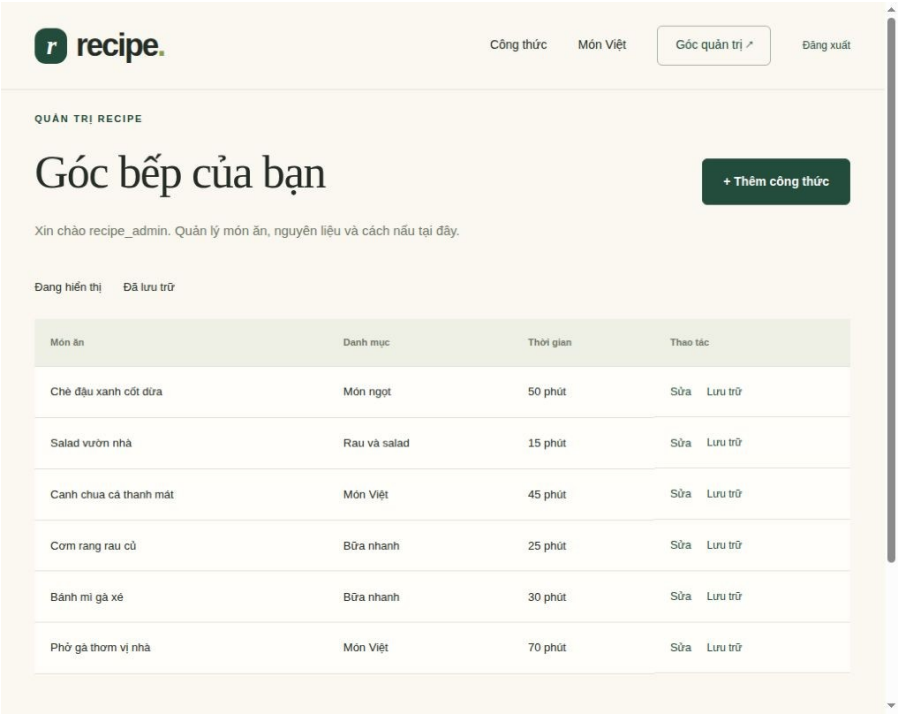
Hình 5 Nguyên liệu và các bước thực hiện của món phở gà

Trang chi tiết đọc một công thức bằng ID, nối tên danh mục và truy vấn các nguyên liệu, các bước theo position. Phần thông tin đầu trang cho biết thời gian sơ chế, thời gian nấu, khẩu phần và độ khó. Người nấu có thể đánh dấu nguyên liệu đã chuẩn bị bằng checkbox; các checkbox chỉ phục vụ thao tác trong giao diện.

Công thức phở gà mẫu có sáu dòng nguyên liệu và năm bước chế biến. Những món khác có cấu trúc dữ liệu tương tự nên quản trị viên có thể chỉnh nội dung mà không cần sửa template. Nút in sử dụng định dạng riêng để bỏ điều hướng và giữ nội dung nấu ăn.

Nếu ID không tồn tại hoặc công thức đã lưu trữ, ứng dụng trả mã HTTP 404 và trang thông báo. Trường hợp này đồng thời tạo dữ liệu để kiểm chứng truy vấn LogQL lọc những yêu cầu lỗi. Ảnh minh chứng trên là giao diện thật sau khi truy xuất database.

6 Đăng nhập và quản trị nội dung



Hình 6 Quản trị viên quản lý các công thức Recipe

Tài khoản quản trị được khởi tạo từ APP_ADMIN_USER và APP_ADMIN_PASSWORD trong .env. Khi đăng nhập, ứng dụng so sánh password hash và đổi session ID. Người dùng chưa có session hợp lệ được chuyển về trang đăng nhập khi truy cập chức năng quản trị.

Thao tác	Kết quả kiểm thử
Thêm	Tạo món mới với nguyên liệu và các bước bằng transaction
Sửa	Cập nhật tên, mô tả, danh mục, thời gian và nội dung
Lưu trữ	Ẩn công thức; truy cập công khai nhận 404
Khôi phục	Đưa công thức trở lại trang công khai

Các thao tác thay đổi dữ liệu dùng POST có CSRF token. Form kiểm tra danh mục hợp lệ, khẩu phần từ 1 đến 50, thời gian tối đa 600 phút và nội dung không được rỗng. Bộ kiểm thử tạo dữ liệu riêng, thực hiện đủ chu trình rồi xóa đúng bản ghi tạm; sáu công thức mẫu vẫn được giữ nguyên.

7 Nginx reverse proxy và security headers

Nginx lắng nghe cổng 8080 trong container và được publish thành 127.0.0.1:8088. Một server block khác lắng nghe 8081 để chuyển tới phpMyAdmin. Ứng dụng và phpMyAdmin không mở cổng trực tiếp ra host. Docker DNS được phân giải lại định kỳ để upstream có thể đổi địa chỉ khi container được tạo lại.

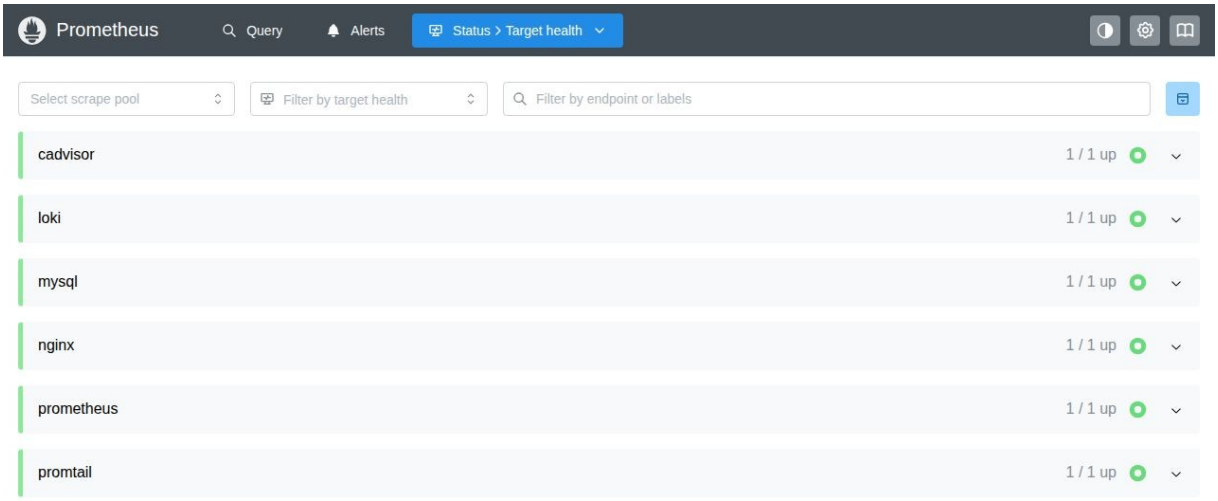
```
resolver 127.0.0.11 valid=10s ipv6=off;
upstream recipe_backend {
    zone recipe_backend 64k;
    server app:8080 resolve;
}
proxy_set_header Host $http_host;
proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
```

Header	Ý nghĩa
X-Content-Type-Options nosniff	Ngăn trình duyệt tự đoán MIME khác với nội dung khai báo
X-Frame-Options SAMEORIGIN	Giới hạn việc nhúng trang trong frame khác nguồn
Referrer-Policy	Giảm thông tin referrer gửi sang nguồn khác
Permissions-Policy	Tắt camera, microphone và geolocation cho website
Content-Security-Policy	Giới hạn nguồn script, style, ảnh, kết nối và form

Bản lab chọn security headers cơ bản theo phương án mà đề bài cho phép. HTTP chỉ chạy trên loopback; không tuyên bố đã triển khai HTTPS cho môi trường Internet. Nginx ẩn phiên bản, chặn các file cấu hình và giới hạn tần suất truy cập trang đăng nhập. Kiểm thử /.env nhận HTTP 403.

Access log Nginx có định dạng JSON với mã HTTP và thời gian đáp ứng. Log dùng URI không kèm query string để hạn chế ghi dữ liệu người dùng. Endpoint stub_status chỉ nằm trong mạng giám sát và được Nginx Exporter sử dụng, không có cổng host riêng.

8 Prometheus và các exporter



Hình 7 Sáu target được Prometheus scrape thành công

Prometheus thu thập mỗi 15 giây từ chính Prometheus, cAdvisor, Nginx Exporter, MySQL Exporter, Loki và Promtail. Kết quả API xác nhận đủ sáu target UP. mysql_up bằng 1 chứng minh exporter kết nối được MySQL; nginx_up bằng 1 chứng minh exporter lấy được stub_status từ Nginx.

```
up
mysql_up
nginx_up
rate(nginx_http_requests_total[2m])
rate(mysql_global_status_questions[2m])
```

cAdvisor cung cấp CPU, RAM và mạng container. Dashboard lọc theo nhãn com.docker.compose.project bằng recipe để tập trung vào bài làm. Prometheus giữ dữ liệu trong named volume, giới hạn retention 7 ngày hoặc dung lượng TSDB 512 MB. Bộ alert rules gồm target down, MySQL down và Nginx down sau một phút; chưa cấu hình gửi thông báo ra dịch vụ ngoài.

9 Dashboard Grafana



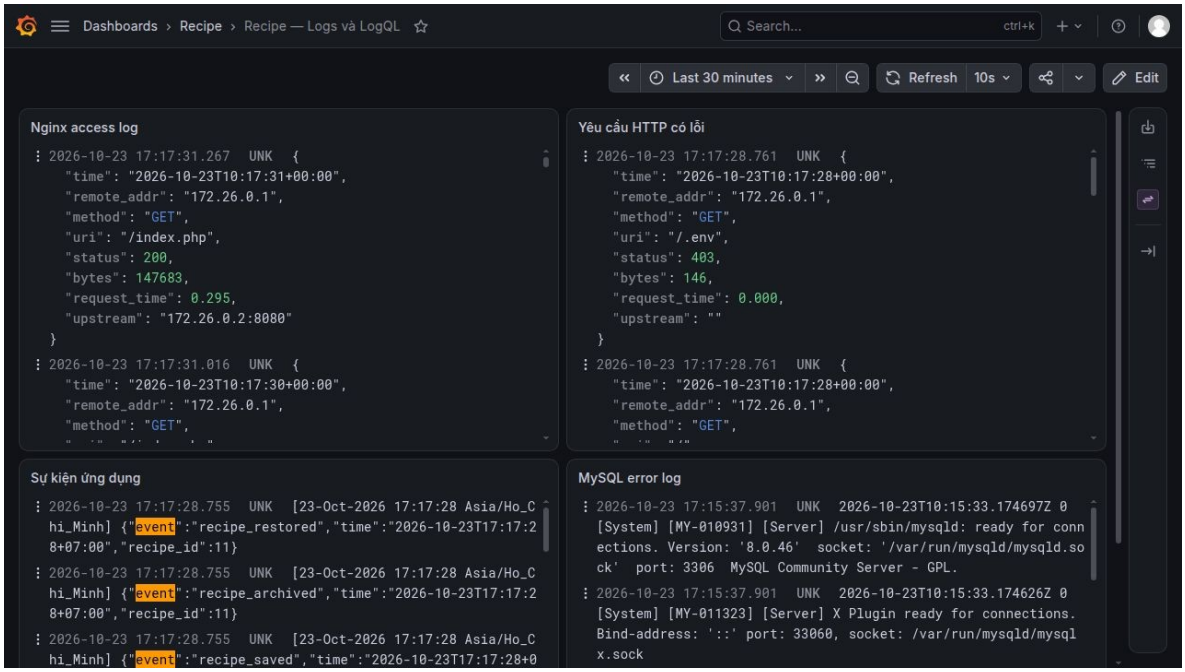
Hình 8 Dashboard metrics của Recipe từ dữ liệu thực

Datasource Prometheus và Loki được khai báo bằng provisioning YAML. Hai dashboard được lưu dưới dạng JSON trong repository và nạp tự động khi Grafana khởi động. Người dùng không phải import dashboard thủ công sau mỗi lần cài mới. API health đã xác minh cả hai datasource hoạt động.

Dashboard metrics có mười panel: số target UP, trạng thái MySQL và Nginx, kết nối MySQL, CPU và RAM theo container, yêu cầu Nginx mỗi giây, kết nối Nginx, số truy vấn MySQL và lưu lượng mạng nhận theo container. CPU dùng rate trong khoảng hai phút; cần có nhiều mẫu scrape để vẽ đường thời gian có ý nghĩa.

Grafana chạy bằng UID 472, dùng filesystem gốc chỉ đọc và volume riêng cho dữ liệu. Chức năng tự cài/cập nhật plugin được tắt để giữ đúng bản plugin đã có trong image và tránh sửa filesystem bất biến. Tài khoản quản trị dùng mật khẩu riêng trong .env; đăng ký công khai và anonymous access đều bị tắt.

10 Log tập trung và truy vấn LogQL



Hình 9 Dashboard log và kết quả truy vấn từ Loki

Nginx, PHP và MySQL ghi log vào ba named volume. Promtail chỉ mount các volume này ở chế độ chỉ đọc, không được cấp Docker socket. Vị trí đọc được lưu trong volume positions; Loki lưu TSDB và chunks trên volume riêng. Nhãn project, job và service giúp chọn đúng nguồn log.

```
{job="nginx"}
{job="nginx"} | json | status >= 400
{job="app"} |= "login_success"
{job="mysql"}
```

Truy vấn đầu liệt kê access log. Truy vấn thứ hai parse JSON rồi lọc mã HTTP từ 400, có các sự kiện 403 và 404 do kiểm thử tạo ra. Truy vấn thứ ba tìm đăng nhập thành công vào ứng dụng; truy vấn cuối đọc log database. Cả bốn truy vấn đều trả bản ghi thực và được lưu trong các file logql-1.json đến logql-4.json.

Mật khẩu, cookie và CSRF token không được ghi vào audit log. Loki đặt retention 168 giờ. Promtail được dùng để đáp ứng đúng yêu cầu học phần; với hệ thống mới đưa vào vận hành thực tế cần xem lộ trình chuyển sang Alloy vì Promtail đã kết thúc hỗ trợ.

11 Hardening container và dữ liệu

Hardening được kiểm chứng trên container đang chạy bằng Docker inspect và thử nghiệm HTTP/SQL. Cấu hình nguồn chỉ là ý định; kết quả runtime trong verification.json cho thấy các biện pháp đã được áp dụng khi triển khai.

Biện pháp	Áp dụng và kết quả
Non-root	App/phpMyAdmin UID 33; Nginx 101; MySQL 999; Grafana 472; Prometheus/exporter 65534; Loki/Promtail 10001
Giảm quyền	Tất cả service bỏ ALL capabilities, bật no-new-privileges và không privileged
Filesystem	Root filesystem chỉ đọc; dữ liệu và log nằm trong volume; file tạm ở tmpfs
Tách mạng	db_net và monitoring_net internal; MySQL không publish cổng; UI chỉ 127.0.0.1
Bí mật	Mật khẩu ngẫu nhiên riêng; .env mode 600; secrets directory mode 700; loại khỏi Git
Quyền DB	Ứng dụng chỉ DML trên database; thử CREATE TABLE nhận lỗi MySQL 1142
Ứng dụng	Băm mật khẩu, CSRF, HTML escape, prepared statements và đổi session ID
Cấu hình ổn định	Image ghim digest, giới hạn RAM và Docker log rotation

Ngoại lệ của collector

cAdvisor là service duy nhất chạy root để đọc cgroups và metadata Docker/containerd. Collector không privileged, không publish cổng và dùng mount host chỉ đọc. Tuy nhiên socket Unix gắn :ro vẫn cho phép gọi API runtime; đây là thành phần phải được tin cậy, không được xem tương đương cách ly hoàn toàn host.

phpMyAdmin chặn đăng nhập root và chỉ dùng tài khoản ứng dụng. Exporter có tài khoản riêng với quyền giám sát chỉ đọc và giới hạn ba kết nối đồng thời. Không sử dụng mật khẩu hoặc private key từ repository tham khảo.

12 Kết quả kiểm thử và khả năng tái lập

Bộ kiểm thử thực hiện 51 kiểm tra và ghi nhận 51 kết quả đạt lúc 17:17:31 ngày 23/10/2026. Dữ liệu thử được tách bằng tên và ID, sau đó dọn đúng bản ghi tạm. Các kết quả chi tiết nằm trong minh-chung/verification.json và verification.txt để có thể đối chiếu lại.

Nhóm kiểm thử	Kết quả quan sát
HTTP và database	Health 200, kết nối PDO thành công, tiếng Việt đúng
Nội dung công khai	Tìm theo nguyên liệu, lọc danh mục, hiển thị nguyên liệu và các bước
Quản trị	Đăng nhập, đổi session, tạo, sửa, lưu trữ và khôi phục
Bảo vệ dữ liệu	CSRF 403, mật khẩu sai 401, SQL injection và XSS được xử lý
phpMyAdmin	Đăng nhập được, nhìn thấy đủ năm bảng ứng dụng
Metrics	Sáu target UP; dữ liệu CPU/RAM; mysql_up và nginx_up bằng 1
Grafana	Hai datasource healthy; dashboard mười panel được provision
LogQL	Bốn truy vấn có kết quả
Runtime	Non-root theo vai trò, cap_drop ALL, read_only và loopback ports
Cài mới	Clone từ GitHub, database và volume mới; health và dữ liệu mẫu hợp lệ

Kiểm tra cài mới sử dụng project Docker Compose riêng và cổng host khác, không dùng volume của hệ thống chính. Kết quả được lưu trong reproducibility.json. Các container và volume thử chỉ được xóa sau khi kiểm tra xong. Kết quả này chứng minh script khởi tạo hoạt động từ mã nguồn đã đẩy lên GitHub, thay vì phụ thuộc hoàn toàn vào dữ liệu có sẵn trên máy.

Ảnh minh chứng chụp từ giao diện đang chạy; JSON lấy từ API và Docker inspect. Không dùng hình dựng để thay cho ảnh kết quả. Các file minh chứng không chứa thông tin đăng nhập.

13 Vận hành sao lưu và kịch bản demo

Khởi động và theo dõi

```
cd DTC245220017_De29-Recipe
python3 scripts/setup.py
docker compose ps -a
python3 scripts/verify.py
docker compose logs --tail=50 app nginx
```

Nếu máy được khởi động lại, restart policy unless-stopped khởi chạy lại các dịch vụ đã chạy. Có thể dùng docker compose stop để tạm dừng và docker compose up -d để chạy lại. Không dùng down -v khi cần giữ database, dashboards, metrics và log. Nếu chỉnh cấu hình Nginx, build lại image và tạo lại container tương ứng.

Sao lưu database

```
python3 scripts/backup.py
```

Script dùng mysqldump với single-transaction và tạo file gzip có quyền 600 trong runtime/backups. Bản sao lưu không được commit. Cần lưu thêm .env bằng phương thức riêng an toàn nếu muốn khôi phục tài khoản và cấu hình sang máy khác. Thao tác phục hồi ghi đè database phải được cân nhắc và sao lưu hiện trạng trước.

Trình tự demo đề xuất

1. Mở GitHub, chỉ rõ README và ba commit triển khai theo giai đoạn.
2. Chạy docker compose ps rồi mở website, tìm một nguyên liệu và lọc danh mục.
3. Mở chi tiết món ăn, minh họa nguyên liệu, các bước và khẩu phần.
4. Đăng nhập quản trị, thêm hoặc chỉnh một công thức và kiểm tra trên website.
5. Mở phpMyAdmin để đối chiếu bản ghi trong MySQL.
6. Mở Prometheus Targets và dashboard Grafana; giải thích các panel container, web và DB.
7. Chạy ba truy vấn LogQL, giải thích một log 403 hoặc 404.
8. Trình bày hardening, kết quả verify.py và cách sao lưu.

14 Đánh giá giới hạn và tài liệu tham khảo

Hệ thống đáp ứng các hạng mục kỹ thuật của Đề 29 trong môi trường lab: ứng dụng công thức nấu ăn, MySQL và phpMyAdmin, reverse proxy, giám sát container/web/database, log tập trung, truy vấn LogQL và hardening. Mã nguồn, cấu hình và hướng dẫn được quản lý chung trong repository, có script khởi tạo và kiểm tra lại.

Các giới hạn cần phân biệt khi trình bày: website chạy HTTP trên localhost với security headers, chưa có chứng chỉ HTTPS cho miền công khai; alert rules chưa nối tới dịch vụ thông báo ngoài; log file nguồn chưa có lịch logrotate; dữ liệu minh họa gồm sáu công thức. Cấu hình nhiều replica, high availability và đánh giá tải lớn không thuộc phạm vi kiểm thử của bản lab này.

Promtail đã hết hỗ trợ ngày 02/03/2026 theo Grafana. Đề bài yêu cầu Loki và Promtail nên bài làm vẫn triển khai thành phần này, đồng thời ghi rõ hướng chuyển đổi sang Alloy cho môi trường vận hành thực. Base image được cố định bằng digest để kết quả cài đặt không thay đổi ngoài ý muốn, nhưng việc cập nhật bảo mật cần được thực hiện có kiểm thử.

Tài liệu tham khảo

Mã nguồn bài làm
https://github.com/longphan632000/DTC245220017_De29-Recipe

Dự án Blog CMS tham khảo
https://github.com/Khanhslee/DTC245220024_De7-Blog-CMS

Nginx stub status
https://nginx.org/en/docs/http/ngx_http_stub_status_module.html

Nginx Prometheus Exporter
https://github.com/nginx/nginx-prometheus-exporter

MySQL Exporter và quyền giám sát
https://github.com/prometheus/mysqld_exporter

Grafana configuration
https://grafana.com/docs/grafana/latest/setup-grafana/configure-grafana/

Promtail và vòng đời hỗ trợ
https://grafana.com/docs/loki/latest/send-data/promtail/

Phụ lục điện tử đi kèm gồm ảnh giao diện, verification.json, bốn kết quả LogQL và kết quả cài mới.